SIZMA TESTİ RAPORU

Rapor Tarihi	12/10/2026
Hazırlayan	Ömer Faruk Baysal
Test Hedefi	PortSwigger Web Academy Lab

1. Access control vulnerabilities in multi-step processes

Bu raporda, PortSwigger Web Security Academy'de yer alan Access control vulnerabilities in multi-step processes ile ilgili iki farklı durum ele alınmıştır.

2. Yönetici Özeti

Yapılan güvenlik testinde, hedef uygulamanın yetki kontrollerinde ciddi eksiklikler tespit edilmiş ve normal/yetkisiz bir kullanıcının yetkili (admin) ayrıcalıklarına veya yetkisiz diğer kullanıcılara yetkisi olmadığı halde erişebildiği gösterilmiştir. Zafiyetin iki farklı biçimde ortaya çıktığı gözlenmiştir.

Yetkisiz yönetici erişimi ve yetkisiz diğer kullanıcı verilerine erişin sistem bütünlüğünün tümüyle tehlikeye girmesine yol açabileceğinden zafiyetin ivedilikle giderilmesi önerilmektedir.

3. Zafiyet Açıklaması

Durum 1: Multi-step process with no access control on one step

Hedef uygulamada yapılan testler sonucunda yetkili hesabının kullanıcı rolünü değiştirme ile ilgili metodunun dışarıdan değiştirilerek yetkisiz kullanıcı hesabı ile de işlem yapılabildiği gözlemlenmiştir.

Durum 2: Referer-based access control

İlk durumdan farklı olarak kullanıcı rolünü değiştirme işleminin doğrudan yönlendirmede parametreler gönderilerek yapıldığı gözlemlenmiştir. Yönlendirmenin yetkisiz kullanıcı tarafından değiştirilmesi ile birlikte zafiyetin sömürülebildiği de PoC adımlarıyla kanıtlanmıştır.

4. Risk Seviyesi

Risk Seviyesi	Yüksek
CVSS v3.1 Skoru	8.1
CVSS v3.1 Vektörü	AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:N
CWE	CWE-285 (Improper Authorization)

5. Etki

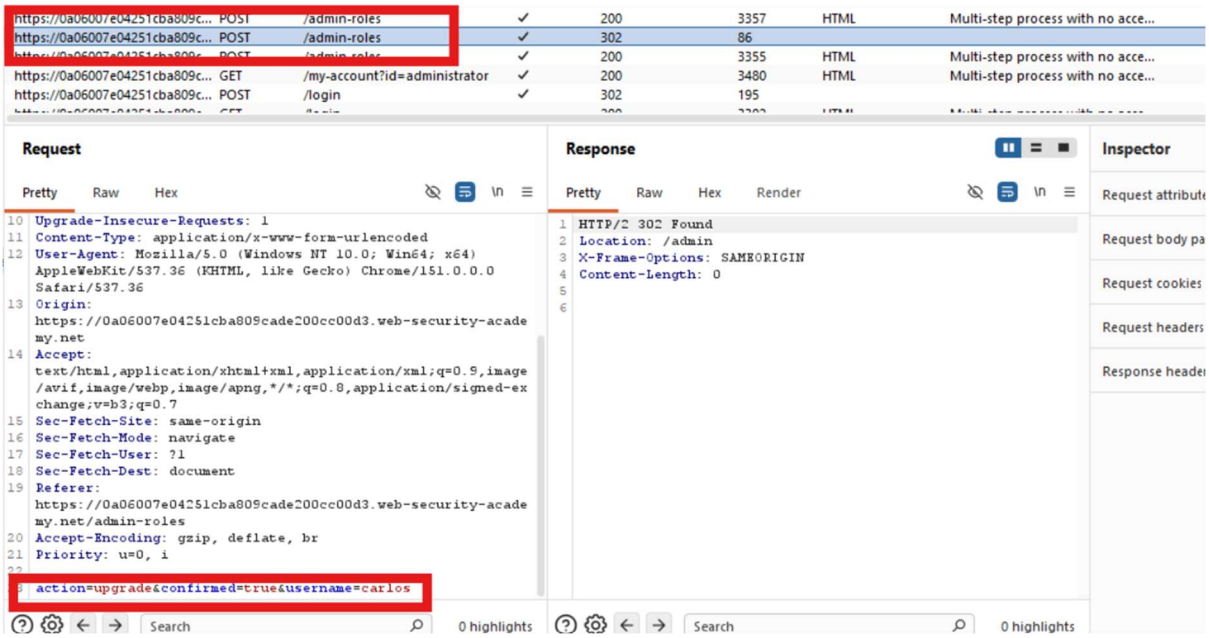
Yapılan testler sonucunda oluşan zafiyetler sayesinde yetkisiz kullanıcının yetkili bir işleve sahip olmamasına rağmen başka kullanıcılar üzerinde o kullanıcı ile ilgili birtakım işlemler yapabildiği gözlemlenmiştr.

Bu zafiyet olası olarak yetkisiz ve yetkili diğer kullanıcılara erişebilme, kullanıcılar adına işlem yapabilme, var olan kullanıcıları silebilme gibi sorunlara da yol açabilme tehlikesi taşımaktadır.

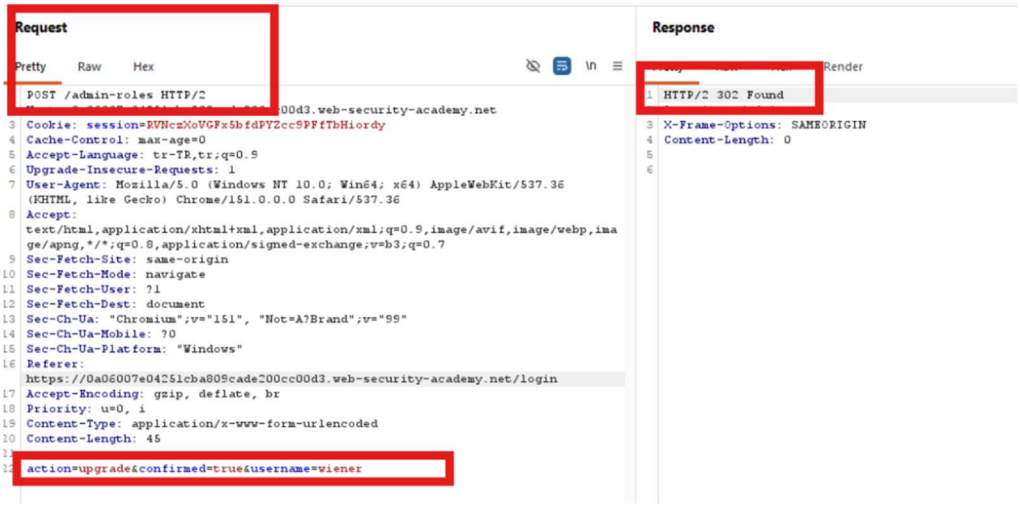
6. Proof Of Concept

Durum 1: Multi-step process with no access control on one step

Verilen kimlik bilgileri ile administrator hesabı incelendiğinde kullanıcıların rollerini değiştirme ile ilgili post metodunun yapısı kopyalanarak yetkisiz kullanıcı tarafından kullanımına açık olduğu görülmektedir.

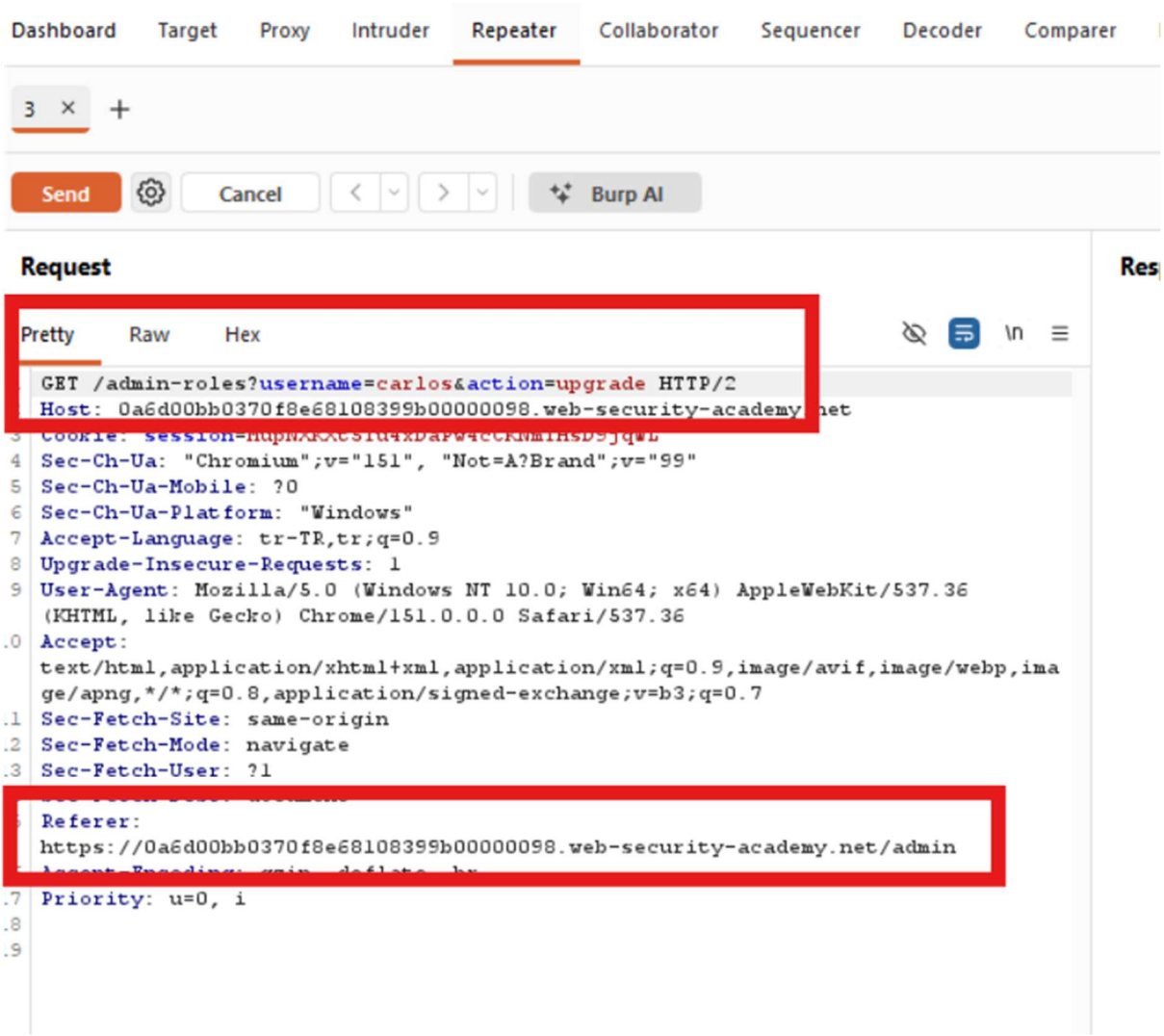


Admin panelde test amaçlı carlos kullanıcının rolü yükseltildiğinde post metonun isteğinde action, confirmed ve username parametrelerinin gerekli olduğu görülmektedir. Verilen yetkisiz kullanıcı olan wiener kullanıcısını kullanarak /my-account ile ilgili get metodunu Burp Repeater'da post metoduna çevirip, gerekli olan bu üç parametreyi de wiener'e göre düzenleyip isteği gönderdiğimiz taktirde wiener kullanıcısının rolünün yükselterek yetkili (admin) olabildiği kanıtlanmıştır.



Durum 2: Referer-based access control

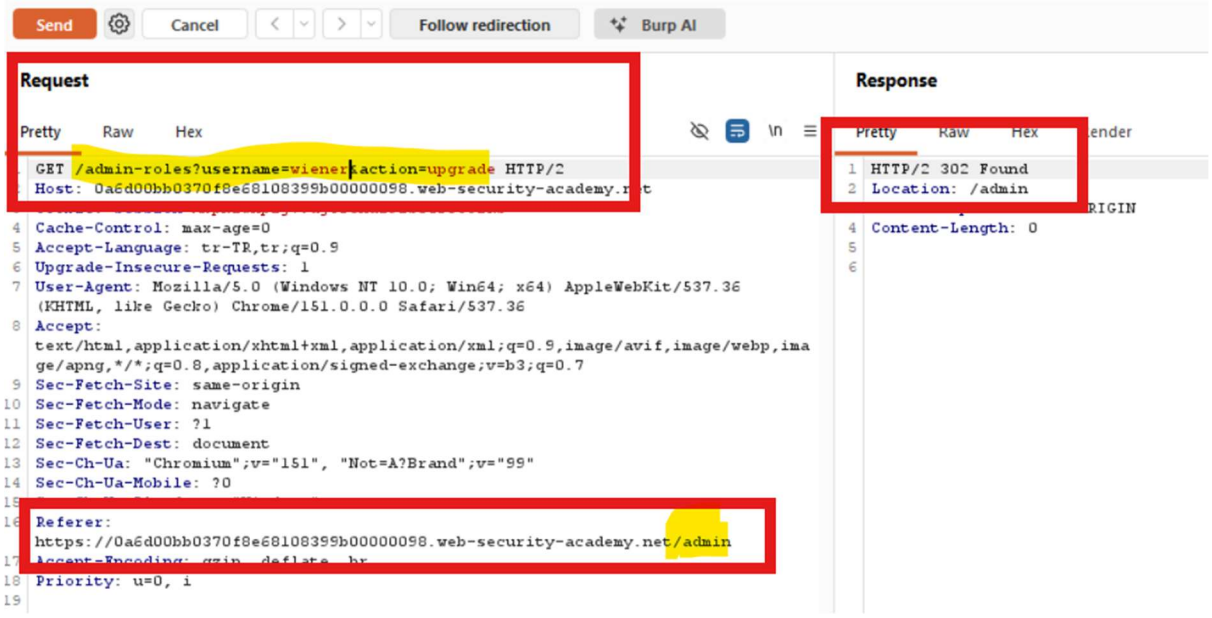
Verilen kimlik bilgileri ile administrator hesabı incelendiğinde kullanıcıların rollerini değiştirme ile ilgili metodun yönlendirme bazlı çalıştığı görülmektedir:



Yönlendirmede parametreler eklenmekle birlikte /admin yoluna yönlendirildiği de gözlemlenmiştir. Yetkisiz kullanıcı olan wiener'in hesabında /my-account isteği incelendiğindiğinde benzer bir yapı görülmektedir:



Metoda ek olarak parametreler eklendiğinde ve /login yönlendirmesi yerine /admin yönlendirmesi yapıldığında yetkisiz kullanıcın rolünü yükseltebildiği ispatlanmıştır.



7. Çözüm Önerisi

Multi-step için: Çok adımlı işlemlerde yetki kontrolü her adımda tekrar yapılmalı; ara/onay adımları “önceki adım zaten doğrulandı” varsayımıyla korumasız bırakılmamalı. Son confirmed=true POST’u tek başına yetkiyi yeniden doğrulamalı.

Referer-based için: Erişim kontrolü Referer gibi istemcinin değiştirebileceği başlıklara dayandırılmamalıdır. Yetki her istekte sunucu tarafında oturum üzerinden doğrulanmalıdır.

8. Sonuç

Yapılan testler sonucunda, hedef uygulamanın yetki kontrollerinin iki farklı biçimde atlatılabildiği ve yetkisiz bir kullanıcının yetkisi olmadığı halde diğer yetkili veya yetkisiz kullanıcılar üzerinde çeşitli işlemler yapılabildiği doğrulanmıştır.

Zafiyet, sistemin tümüyle ele geçirilmesine kadar ilerleyebilecek etkisi nedeniyle yüksek risk seviyesinde değerlendirilmiş olup, önerilen önlemlerin uygulanarak ivedilikle giderilmesi tavsiye edilmektedir.